Data Privacy and Retention

deleting a user means everywhere

Watch the 4-min video

In one line: collect only what you need, keep it only as long as you need it, and be able to find and erase a person's data everywhere it was copied, using a data map, deletion events that every owner confirms, enforced retention, and crypto-shredding for backups.

1 "Delete my account"

The app deletes the row from `users`. Done? The person's data is still in the search index, the analytics warehouse, the logs, three caches, the event stream and last month's backups. Under GDPR (Article 17, right to erasure) and India's DPDP Act 2023, it all has to go, normally within one month of the request.

2 The principles

- **Data minimisation**: collect only what the feature needs. Data you never stored can't leak.
- **Purpose limitation**: use it only for the purpose you stated.
- **Storage limitation**: keep it only as long as necessary.
- **Data subject rights**: access, correction, erasure, portability.

The laws apply to any company serving people in those regions. GDPR fines reach €20 million or 4% of worldwide annual turnover, whichever is higher; DPDP penalties reach ₹250 crore per breach.

3 Erasure in a distributed system

You can't delete what you can't find. Keep a **data map**: every store that holds personal data, which fields, and which team owns it. Keep it in code (schema annotations, a catalog generated in CI) so it doesn't go stale. Then make deletion an event every owner handles.

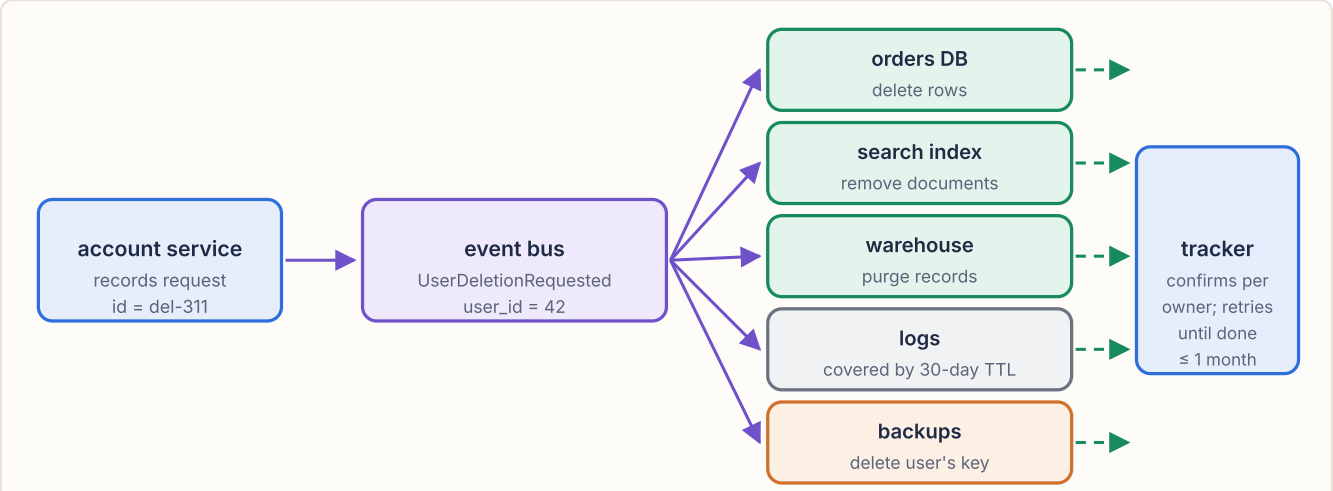


Figure 1. Deletion as an event: each owning service deletes and confirms; a tracker retries until every owner is done.

4 Backups and retention



or: keep backups short-lived, and replay pending deletions after any restore

Figure 2. Backups can't be rewritten row by row. Crypto-shredding (lesson 47) makes old copies unreadable instead.

Retention schedules make the rest automatic. Decide per data type, then enforce with TTLs and lifecycle rules, not good intentions:

Data	Example retention	Enforced by
raw application logs	30 days	log platform retention setting
session and analytics events	13 months, then aggregate	warehouse partition expiry
orders	while the account exists + 1 year	scheduled purge job
invoices	as tax law requires (often 6–10 years)	object storage lifecycle rule

Legal obligations can override erasure (you may have to keep invoices), so delete everything else and restrict access to what you must keep. Old data you no longer need is pure risk: it can only leak.

5 Anonymised vs pseudonymised

Pseudonymised data swaps names for tokens but can be re-linked with a key, so it is still personal data under GDPR. **Anonymised** data can't be linked back to a person by any reasonable means, and falls outside the law. That's harder than it looks: Latanya Sweeney showed that ZIP code, birth date and gender alone identify about 87% of Americans. Use aggregation, k-anonymity or differential privacy, not just dropping the name column.

WORKED EXAMPLE: DELETING A USER EVERYWHERE

The account service records request `del-311`, disables login at once, and publishes `UserDeletionRequested{user_id: 42}`. Orders, search and the warehouse consume it, delete, and publish confirmations; logs are covered by 30-day retention; backups by deleting user 42's key. A tracker shows per-owner status and retries failures until all confirm, well within one month. Each step is idempotent, so replays are safe.

COMMON MISTAKES

- Deleting from the primary database only, forgetting caches, indexes, warehouses and streams.
- Calling hashed emails or user IDs “anonymous”.
- Keeping everything forever “in case it's useful”.
- Restoring an old backup and silently resurrecting deleted users.

6 Key terms

Data minimisation: collect only what you need

Data map: inventory of where personal data lives and who owns it

Storage limitation: keep data only as long as necessary

Right to erasure: GDPR Art. 17: have your data deleted

Pseudonymisation: identifiers replaced, re-linkable with a key

Anonymisation: can't be linked back to a person at all

7 Interview questions

Q1. What's the difference between anonymisation and pseudonymisation? BASIC

Pseudonymised data replaces identifiers with tokens but can be re-linked with a key, so it's still personal data; anonymised data can't be linked back to a person at all.

Q2. What is data minimisation? BASIC

Collecting and keeping only the personal data a purpose needs, which also shrinks what a breach can expose.

Q3. How do you implement “delete my data” across a distributed system? SCENARIO

Keep a data map; publish a deletion event that every owning service handles and confirms, retrying failures; track completion; cover logs with short retention and backups with crypto-shredding.

Q4. How do you stop a backup restore from bringing deleted users back? SCENARIO

Keep a durable log of completed deletions and replay it after any restore, or rely on crypto-shredding so restored rows stay unreadable.

Q5. A user asks for erasure, but you must keep their invoices for tax law. What do you do? TRICKY

Erase everything else, keep only the legally required records, restrict access to them, and delete them when the legal period ends; tell the user why.

Q6. Is a SHA-256 hash of an email address anonymous? TRICKY

No. Anyone with a list of emails can hash them and match, so it's pseudonymous at best and still personal data.

Next: SD-M-019 · Multi-Tenant Isolation backendroadmap.com